



# คันนี้ดีไหม?

Sprint 0-2 · ตุลาคม 2569

ระบบค้นหาและรีวิวรถเมล์ ขสมก. รายคัน ด้วยเลขข้างรถ พร้อมระบบแจ้งเตือนและการดูแลเนื้อหา — รายงานสรุปโปรเจกต์

ทีม 3 คน:

เว็บ: [env-0241390.proen.app.ruk-com.cloud](http://env-0241390.proen.app.ruk-com.cloud)

โค้ด: [github.com/i2x/bus](https://github.com/i2x/bus)

**สรุป** — ผู้โดยสารรู้จากแอปอื่นว่ารถอยู่ไหน แต่ไม่รู้ว่**คันนี้**ควรขึ้นไหม เราทำเว็บที่กรอกเลขข้างรถ (เช่น **7-3077**) แล้วเห็นรุ่น เขต อยู่ ค่าโดยสาร และคะแนนจากผู้โดยสาร 3 ด้าน (การขับ · การจองป้าย · สภาพรถ) ผู้ใช้ได้แ่ตามจากรีวิวที่มีประโยชน์และนำแ่ตามไปแลกสติกเกอร์/รูปโปรไฟล์ได้ รีวิวที่ผิดกติกาถูก report และผู้ดูแลซ่อนพร้อมหักแ่ตามได้ เข้าสู่ระบบด้วยบัญชี Google จริง ระบบรันจริงบน ruk-com (Nginx · Node.js 22 · PostgreSQL 16) มี test อัตโนมัติ 14 ชุด และ backup รายวันที่ทดสอบกู้คืนแล้ว

## 1 ปัญหาและลูกค้า

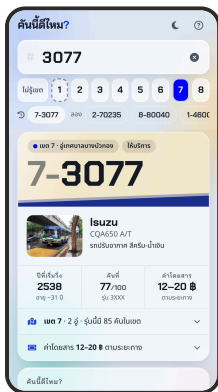
### ปัญหา

- ViaBus / แอป ขสมก. บอกตำแหน่งและสาย แต่ไม่บอกว่าคันนั้นแอร์หรือพัดลม รุ่นอะไร ค่าโดยสารเท่าไร
- ไม่มีช่องทางให้คะแนนคุณภาพการขับ: ขับหวาดเสียว ไม่จอดป้าย จอดกลางถนน
- ร้องเรียน 1348 ได้ แต่ผู้โดยสารคนอื่นไม่เห็นผล ต่างจาก Grab / LINE MAN ที่ให้ดาวได้ทุกเที่ยว

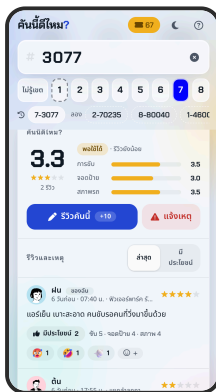
### ลูกค้า

- ผู้โดยสารประจำ** (กลุ่มหลัก) — นักเรียน นักศึกษา คนทำงานที่ขึ้นสายเดิมทุกวัน
- ผู้ประกอบการเดินรถ** (Phase 2) — feedback รายคันใช้ประเมินคนขับ
- หน่วยงานกำกับ** (อนาคต) — ข้อมูลรวมด้านความปลอดภัยแยกสาย/เขต/อู่

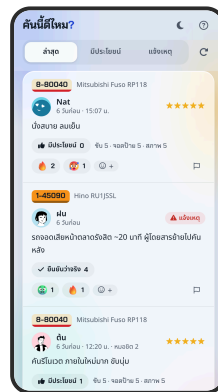
## 2 สิ่งที่ทำได้ (ภาพจากเว็บจริง)



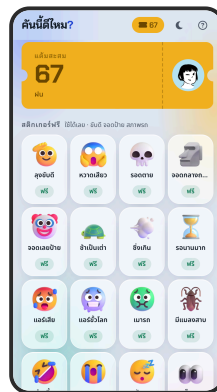
**คันเลขข้างรถ**  
รุ่น เขต อยู่ ค่าโดยสาร



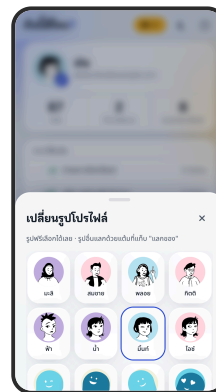
**คะแนน + รีวิว**  
3 ด้าน · สติกเกอร์ · report



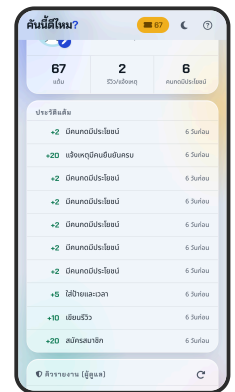
**Feed**  
ล่าสุด · มีประโยชน์ · แจ้งเหตุ



**ร้าน 75 ขึ้น**  
ฟรี 31 · แลกแ่ตาม 44



**เลือกรูปโปรไฟล์**  
ฟรี 12 แบบตอนสมัคร



**ฉัน + คิวผู้ดูแล**  
แ่ตาม · ประวัติ

ข้อมูลรุ่นรถ 13 รุ่น 8 เขต จากวิกิพีเดีย "องค์การขนส่งมวลชนกรุงเทพ" (CC BY-SA) · รูปสติกเกอร์ Microsoft Fluent Emoji (MIT) · รูปโปรไฟล์ DiceBear (CC0 / CC BY 4.0) · รีวิวในภาพเป็นข้อมูลทดสอบของทีม · ตัดตั้งเป็นแอปบนมือถือได้ (PWA)

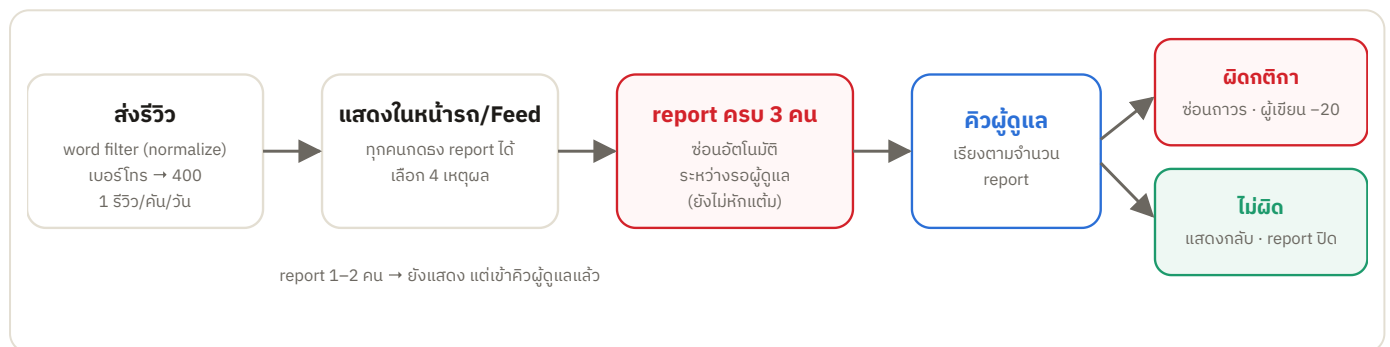
### 3 ระบบแต้มและกติกา

| เหตุการณ์                                                              | แต้ม           |
|------------------------------------------------------------------------|----------------|
| เข้าด้วย Google ครั้งแรก                                               | +20            |
| เขียนรีวิว + ดาว 3 ด้าน                                                | +10            |
| ใส่ป้ายและเวลาที่ขึ้น                                                  | +5             |
| มีคนกด "มีประโยชน์" (เพดาน 30/วัน)                                     | +2             |
| แจ้งเหตุ มีคนยืนยันครบ 3                                               | +20            |
| แลกสติ๊กเกอร์ / รูปโปรไฟล์ (สติ๊กเกอร์เรื่องรถ 19 + รูปโปรไฟล์ 12 ฟรี) | -10...<br>-100 |
| รีวิวถูก report และผู้ดูแลยืนยันว่าผิด                                 | -20            |

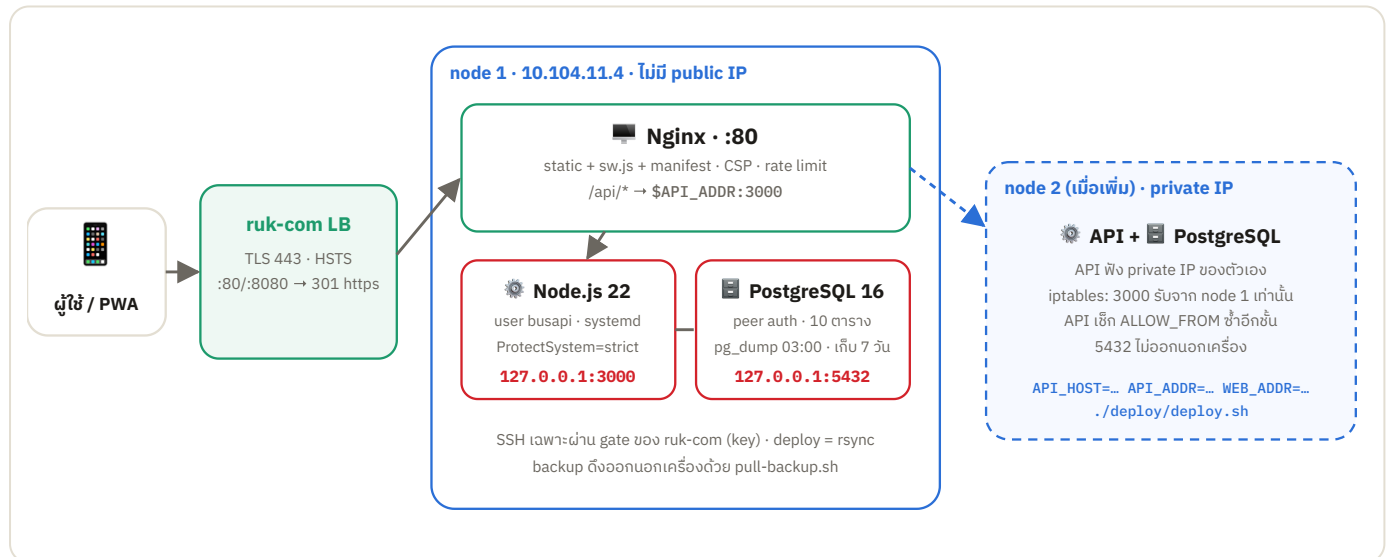
#### ก้นโงง (server ตรวจสอบ ไม่พึ่งหน้าเว็บ)

- ทุกการเปลี่ยนแต้มเป็น 1 แถวใน `points_ledger` · ยอด = `SUM(delta)` · ตรวจสอบย้อนหลังได้
- รีวิว + แต้ม อยู่ใน transaction เดียว · 1 รีวิว/คัน/วัน ด้วย partial unique index
- โหวต/report/ของที่แลก เข้าไม่ได้ด้วย primary key / unique
- แลกของล็อกแถวผู้ใช้ ( `FOR UPDATE` ) – กดพร้อมกันได้ของชิ้นเดียว แต้มไม่ติดลบ
- สติ๊กเกอร์ไม่ให้แต้ม · ต้องแลกก่อนใช้
- รีวิว "คัน" ไม่ใช่ "คน": ห้ามชื่อ/รูปคนขับ · กรองคำหยาบ · ห้ามเบอร์โทร · ไม่รับรูป

#### การดูแลเนื้อหา



### 4 สถาปัตยกรรม



### ที่ deploy จริง

- ruk-com: TLS จบที่ load balancer · เครื่องไม่มี public IP · เข้าได้ทาง LB (เว็บ) และ SSH gate (key) เท่านั้น
- Web: Nginx เซิร์ฟหน้าเว็บ + reverse proxy `/api` · rate limit 10 req/s (เข้าสู่ระบบ 10/นาทีก) · CSP
- App: Node.js 22 + Express รันเป็น user `busapi` ผ่าน systemd · พัง 127.0.0.1
- Data: PostgreSQL 16 ผ่าน unix socket แบบ peer auth (ไม่มีรหัสผ่าน DB) · พัง 127.0.0.1
- Deploy คำสั่งเดียว `./deploy/deploy.sh` (rsync + npm ci + migrate + restart)

### ต่างจากแบบใน Sprint 0

- แบบ: AWS VPC 2 subnet · จริง: ruk-com ไม่มี VPC → แยก tier ด้วย bind 127.0.0.1 และเตรียมสคริปต์ย้าย API + DB ไป node ที่ 2 (private IP + iptables + ALLOW\_FROM) — **ยังไม่ได้เพิ่ม node**
- Docker Compose → systemd · Let's Encrypt → TLS ที่ LB
- รหัสผ่าน + bcrypt → เข้าด้วย Google เท่านั้น (ไม่มีรหัสผ่านในระบบ) · มีบัญชีทดสอบ `@example.com` เปิดคู่ไว้สำหรับ เติมน

## 5 REST API และข้อมูล

| ENDPOINT                                                                                      | ทำอะไร                                                                     |
|-----------------------------------------------------------------------------------------------|----------------------------------------------------------------------------|
| <b>GET</b> <code>/api/health</code> · <code>/api/config</code>                                | สถานะ API+DB · เปิด Google จริงหรือยัง                                     |
| <b>POST</b> <code>/api/auth/google</code>                                                     | เข้าสู่ระบบ → JWT 15 นาที + refresh cookie                                 |
| <b>POST</b> <code>/api/auth/refresh</code> · <code>logout</code>                              | หมุน / เพิกถอน refresh token                                               |
| <b>GET</b> <code>/api/me</code>                                                               | โปรไฟล์ · แด้ม · ประวัติ · ของที่มี                                        |
| <b>DEL</b> <code>/api/me</code>                                                               | ลบบัญชีและข้อมูลทั้งหมด                                                    |
| <b>POST</b> <code>/api/me/avatar</code>                                                       | ใช้รูปโปรไฟล์ที่แลกมา                                                      |
| <b>GET</b> <code>/api/buses/{fleetNo}[/reviews]</code>                                        | คะแนนเฉลี่ย 3 ด้าน · รีวิวของคันนั้น                                       |
| <b>POST</b> <code>/api/reviews</code>                                                         | รีวิว / แจ้งเหตุ + แด้ม                                                    |
| <b>POST</b> <code>/api/reviews/{id}/helpful</code> · <code>react</code> · <code>report</code> | มีประโยชน์ · สติ๊กเกอร์ · รายงาน                                           |
| <b>GET</b> <code>/api/feed</code>                                                             | <code>sort=new top</code> · <code>type=incident</code> · <code>zone</code> |
| <b>GET</b> <code>/api/rewards</code>                                                          | ของในร้าน                                                                  |
| <b>POST</b> <code>/api/rewards/{id}/redeem</code>                                             | แลกของ                                                                     |
| <b>GET</b> <code>/api/mod/reports</code>                                                      | คิวผู้ดูแล (role จาก DB)                                                   |
| <b>POST</b> <code>/api/mod/reviews/{id}/resolve</code>                                        | <code>hide (-20)</code> / <code>keep</code>                                |

| ตาราง                         | เก็บอะไร                                           |
|-------------------------------|----------------------------------------------------|
| <code>users</code>            | email, google_sub, ชื่อ, avatar, role              |
| <code>buses</code>            | fleet_no "7-3077", zone, model_id                  |
| <code>reviews</code>          | type, ดาว 3 ด้าน, ข้อความ ≤500, ป้าย, เวลา, status |
| <code>review_votes</code>     | PK (review, user)                                  |
| <code>points_ledger</code>    | delta, reason, ref_id, note                        |
| <code>rewards</code>          | sticker / avatar, ราคา                             |
| <code>user_rewards</code>     | PK (user, reward)                                  |
| <code>review_reactions</code> | PK (review, user) → sticker                        |

| ตาราง          | เก็บอะไร                                 |
|----------------|------------------------------------------|
| reports        | เหตุผล, open/upheld/dismissed, ผู้ตัดสิน |
| refresh_tokens | sha256, family, หมดอายุ, เพิกถอน         |

6 ความปลอดภัย (ตรวจบน server จริง 8 ต.ค. 2569)

| มาตรการ                       | หลักฐาน / วิธีตรวจ                                                                                                                                                                                                  |
|-------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| API / DB ไม่เปิดออกนอกเครื่อง | ss -ltn → 0.0.0.0:80 · 127.0.0.1:3000 · 127.0.0.1:5432 · nmap จากภายนอก: 3000, 5432 = filtered                                                                                                                      |
| บังคับ HTTPS                  | http (80, 8080) → 301 https · HSTS จาก LB (Nginx เอาของตัวเองออกแล้ว ไม่ให้ header ชั่ว)                                                                                                                            |
| Authentication                | ไม่มีรหัสผ่านในระบบ · access JWT 15 นาที · refresh token ใน cookie HttpOnly; Secure; SameSite=Strict เก็บใน DB เป็น sha256 · หมุนทุกครั้ง · ใช้ซ้ำ = เพิกถอนทั้งชุด · Google จริงตรวจ aud, iss, email_verified, exp |
| Authorization                 | JWT middleware · moderator อ่าน role จาก DB ทุก request                                                                                                                                                             |
| Input                         | parameterized SQL ทุกจุด · validate ทุก field · body ≤ 10 KB · word filter + กันเบอร์โทร                                                                                                                            |
| XSS / clickjacking            | escape ทุกข้อความก่อนแสดง · CSP · X-Frame-Options SAMEORIGIN · nosniff · Permissions-Policy                                                                                                                         |
| Rate limit                    | Nginx: /api 10 req/s burst 20 · เข้าสู่ระบบ 10 req/นาที → 429                                                                                                                                                       |
| Least privilege               | API รันเป็น busapi + systemd ProtectSystem=strict · secret ใน /etc/bus-api.env (640) · DB peer auth                                                                                                                 |
| Patch                         | Node 18 (หมดชีพพอร์ต) → 22 LTS จาก nodejs.org ตรวจ SHA256                                                                                                                                                           |
| Backup                        | pg_dump ทุกวัน 03:00 เก็บ 7 วัน · ทดสอบ restore แล้วจำนวนแถวตรงกับของจริง · pull-backup.sh ดึงออกนอกเครื่อง                                                                                                         |
| ข้อมูลส่วนบุคคล               | เก็บแค่อีเมล + ชื่อต้นจาก Google · ไม่เก็บตำแหน่ง · ไม่มีรูป · ลบบัญชีเองได้ · มีหน้า /privacy.html                                                                                                                 |

```
$ nmap -Pn -p 22,80,443,3000,3022,5432,8080 env-0241390...
22/tcp    filtered  ssh
80/tcp    open      http      (→ 301 https)
443/tcp   open      https
3000/tcp   filtered  (API)
3022/tcp   open      (SSH gate ของ ruk-com)
5432/tcp   filtered  postgresql (DB)
8080/tcp   open      http-proxy (→ 301 https)
```

```
$ bus-restore-test.sh
backup : bus-2026-10-08-1116.dump
restore: 6 users, 7 reviews, 33 ledger rows
live   : 6 users, 7 reviews, 33 ledger rows

$ curl -X POST .../api/auth/refresh (หลัง logout)
401
```

สแกนเฉพาะพอร์ตที่เกี่ยวข้องกับระบบ เพราะ IP นี้เป็น load balancer ที่ใช้ร่วมกับลูกค้าอื่น · 3022 และ 8080 เข้าใจว่าเป็นของ LB/ruk-com ไม่ใช่เครื่องเรา

## 7 การทดสอบ

### อัตโนมัติ — `cd api && npm test`

สร้างฐานข้อมูลทั้งได้ `bus_test` → เปิด API จริง → ยิง HTTP 14 ชุด (ผ่านทั้งหมด): เข้าสู่ระบบ, รีวิว, word filter, มีประโยชน์, แลกของ, แลกพร้อมกัน, ของฟรี, รูปโปรไฟล์, สติ๊กเกอร์, report, moderator, refresh token, ลบบัญชี — ทุกกรณีที่ต้องถูกปฏิเสธ (400/401/403/409) มี test

### บน server หลัง deploy

`curl` ตรวจสอบ header, 301, endpoint ใหม่, refresh/logout ผ่าน LB จริง · ทดสอบ restore backup · nmap · ภาพหน้าจอทุกหน้าในรายงานนี้ถ่ายจากเว็บจริงหลัง deploy

**บักที่เจอและแก้:** "เสียมาก" หลุด filter (เจอจาก test) · logout แล้วยัง refresh ได้ภายใน 20 วินาที (เจอบน server) — เพิ่ม test ทิ้งคู่

## 8 ผลแต่ละ Sprint

| SPRINT   | เป้าหมาย                                                                       | ผล                                                                                               |
|----------|--------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------|
| 0 · ก.ย. | ปัญหา / ลูกคำ / โซลูชัน · ออกแบบ architecture · ต้นแบบ ค้นหา                   | One-pager + pitch · หน้าค้นหาใช้ได้บน GitHub Pages                                               |
| 1 · ต.ค. | API + DB + Nginx/HTTPS + หน้ารีวิว + deploy                                    | ครบ 5/5 + ถึงงาน Sprint 2 มาได้ 3 (ledger, feed, มีประโยชน์) · เปลี่ยนเป็น Google Sign-In (mock) |
| 2 · ต.ค. | แลกของ · report/moderator · refresh token · PWA · security + backup · แยก node | เสร็จ 12 (รวม Google Sign-In จริง) · รอ node ที่ 2 · ทดลองกับผู้ใช้ ↓                            |

## 9 ทดลองกับผู้ใช้

คนที่ลอง \_\_\_\_\_ คน · สาย \_\_\_\_\_ · รีวิว \_\_\_\_\_ · แจ้งเหตุ \_\_\_\_\_ · ใส่ป้าย+เวลา \_\_\_\_\_ % · แลกของ \_\_\_\_\_ คน · ติดตั้ง PWA \_\_\_\_\_ คน  
สิ่งที่ได้ยิน / ที่ปรับ: \_\_\_\_\_  
ทีมกรอกจากข้อมูลจริง — ถึงตัวเลขได้จาก `SELECT reason, count(*) FROM points_ledger GROUP BY 1`

## 10 ข้อยกเว้นและงานต่อ

### ข้อยกเว้น

- ยังเปิดบัญชีทดสอบคู่กับ Google จริง (ปิดได้ด้วย `MOCK_LOGIN=0`)
- ยังเครื่องเดียว · backup อยู่เครื่องเดียวกับ DB ถ้าไม่ได้ดึงออก
- word filter เป็นรายการคำ คำใหม่หลุดได้ — พึ่ง report
- ยังไม่แจ้งผู้เขียนเมื่อรีวิวถูกซ่อน · ไม่มีอุทธรณ์
- ค่าแต้มเป็นค่าที่ทีมตัวเอง ยังไม่ได้ปรับจากข้อมูลจริง

### งานต่อ

- ปิดบัญชีทดสอบหลังเดโม ( `MOCK_LOGIN=0` )
- เพิ่ม node ที่ 2 → `API_HOST=... API_ADDR=... WEB_ADDR=... ./deploy/deploy.sh` → nmap ซ้ำ
- ติดตามสาย / feed ตามสาย · badge จากยอดรีวิว
- B2B: สรุปคะแนนรายชื่อ/รายชื่อให้ผู้ประกอบการ